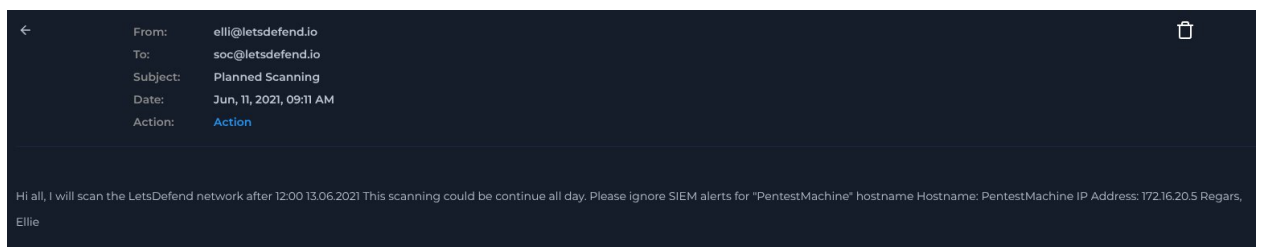


Event Information:

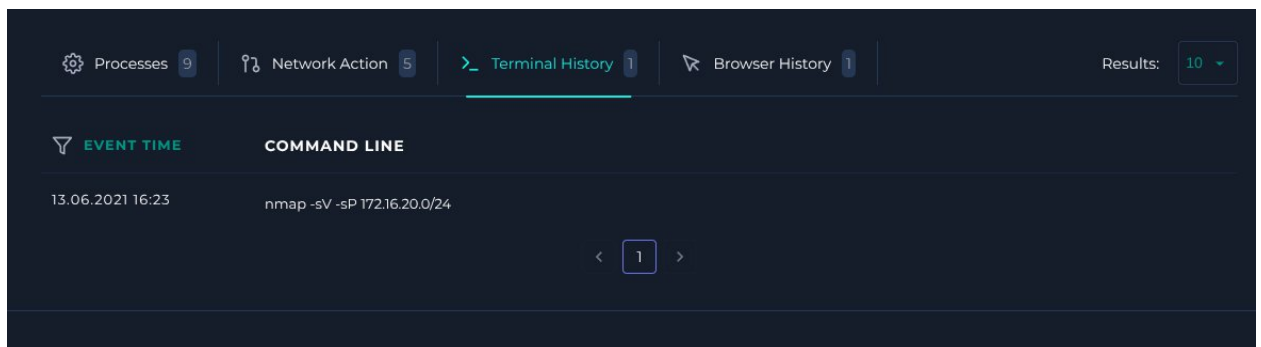
EventID :
94
Event Time :
Jun, 13, 2021, 04:23 PM
Rule :
SOC147 - SSH Scan Activity
Level :
Security Analyst
Source Address :
172.16.20.5
Source Hostname :
PentestMachine
File Name :
nmap
File Hash :
3361bf0051cc657ba90b46be53fe5b36
File Size :
2.82 MB
Device Action :
Allowed

Analysis Steps:

The source hostname of PentestMachine with an internal IP was deemed to be of interest and when searching for emails with this hostname the following was found.



The machine is verified to be on the organisation's network with the stated IP and the command to run the Nmap scan which triggered the alert is visible.



The gathered information was enough to declare the incident as a False Positive.

Report:

Incident Summary

Analysis confirms a False Positive alert regarding SSH scanning activity originating from the host PentestMachine (172[.]16.20.5). Internal email correlation verified that this activity is part of an authorised internal penetration testing programme conducted by a verified security team member. No malicious compromise occurred.

Incident Details

- **Alert Name:** SOC147 - SSH Scan Activity
- **Source Host:** PentestMachine (172[.]16.20.5)
- **Flagged File:** Nmap
- **Alert Trigger:** Network scanning behaviour detected targeting port 22 (SSH).

Analysis and Evidence

- **Internal Correlation:** An email was located in the internal logs from elli@letsdefend.io to the SOC team, explicitly detailing a planned network scan occurring on 13/06/2021.
- **Scope Verification:** The source IP (172[.]16.20.5), hostname (PentestMachine), and time of the alert perfectly align with the parameters outlined in the authorisation email.

Actions Taken

1. Correlated the alert with internal communications regarding scheduled penetration testing.
2. Verified the source IP, hostname, and time-frame matched the approved testing scope outlined by the sender.
3. Declared the alert as a False Positive.

Let's Defend Result

SOC147 - SSH Scan Activity

False Positive (+5 Point)

Analyze Malware (-5 Point)

Check if the malware is quarantined/cleaned (+5 Point)

It seems LetsDefend deemed listing Nmap as non-malicious to be incorrect. I am unsure why this would be. If I am not mistaken you must list Nmap as malware to receive full points for this alert.

When I re-examined and listed that malware was found everything was correct in the result section.

SOC147 - SSH Scan Activity

False Positive (+5 Point)

Check If Someone Requested the C2 (+5 Point)

Analyze Malware (+5 Point)

Check if the malware is quarantined/cleaned (+5 Point)

Wherever I searched the MD5 hash it was listed as being Nmap and that checks out with the contents of this alert.

If I am not missing something here then I do not agree with LetsDefend's decision of considering Nmap to be malware.